HSLU Lucerne University of Applied Sciences and Arts

Sicherheit in der Produktentwicklung SPREN1

Woche 1



Information Technology
September 17, 2026

FH Zentralschweiz

Agenda (heute)

- Vorstellung Dozierende
- Vorstellung Semesterablauf
- Konzept SPREN
- Wissenschaftliches Arbeiten
- Vorbereitung Vorstellungsrunde 5-10
- Vorstellungsrunde jeder 1 Minute
- Gruppenzuteilung
- Fallstudie
- Hinweise/ Logistik/ Modulendprüfung

Bio Alex Diekmann

Lecturing at HSLU part-time since 2019

Main Job at u-blox

CSO / Head of Enterprise Risk Management / Head of Business Continuity & Crisis Management, covering

- Information Security (NIS2-covered IT Infrastructure, Dev. & Prod. Infrastructure, Cloud Services)
- Product Security (CRA-covered Modules & Chips for GNSS, Wifi, Bluetooth + Cloud Services)
- Site Security (30 Offices in EMEA, APAC and NALA)
- Supply Chain Security (Contract Manufacturers, Component Suppliers etc.)
- Enterprise Risk Management
- Business Continuity Management, Emergency & Crisis Management

Before (2007-2018) at Roche

- Built up and lead the Diagnostics Product CERT
- Medical Device Security Expert, Process Manager, Service Manager & Project Lead
- Part-time Internal Auditor ISO13485 QMS
- Integrated Security Testing & Threat Modelling with the Safety-based Development & Risk Management Processes

Education & Certificates

- Executive MBA
- Bachelor of Engineering IT
- CISA
- CISM
- SEI Software Architecture Professional
- ISO13485 QMS Internal Auditor
- ISO27001 Lead Auditor
- ISO27032 Lead Cybersecurity Manager
- ISO21434 Cybersecurity Red Belt
- Certified DevSecOps Professional
- ISO22301 Business Continuity Management System Lead Implementer



That's what I looked like before the 2022 Cyber Incident…

Private

- Father of 2
- School Board member KSR
- Various club memberships

Bio Chris Ditze-Stephan



Personal:
- 58 years
- Father and Grandfather
- Interests: Archery, Guitar Playing, Entrepreneurship Support

Professional Career:
- Position: Managing Director at Zentric DE and CH (1999)
- Active in the field since 1984

Expertise:
- Specialized in Information and Cybersecurity within ICT and OT infrastructures

Industry Knowledge:
- Medical Devices, Transportation/Rail, Finance, Legal/Law, Government Sectors

Teaching Roles:**

- Lecturer on Product Cybersecurity, eEspionage, System Analysis, Privacy, Security Management, Incident Response and BSI Basic Protection

More on LinkedIn.

Twitter:https://twitter.com/hintz2010
LinkedIn:https://www.linkedin.com/in/chris-ditze-stephan/
Email:cds@zentric.com

Lothar Gramelspacher (CISA; CISSP; CISM; 27001 LA; ...)



- Own ISP 1994 (got hacked!)
- Founding member "auditor"
  --> backtrack --> kali linux
- Big (~~5~~ 4) IT Audit Banken
- Big Pharma
  - Deputy CISO
  - Product Security Dia
- HSLU MV SPREN & Dozent ISLAB
- Security Kritische Infrastruktur
  - Stromnetz & Medizingeräte
- CISO Startup Bank
- Diverse Audit & Beratungsmandate
- Dozent Swiss Universities MSE SecIndOpt & HSLU Introl

- ausserdem
  - frickelt gerne IT (aber nicht für andere)
    - eigenes Home Lab
    - Hausautomatisierung
  - Tourismus (airbnb host)
  - Schoko Trüffel
  - ... ;-)

Online Netiquette

zoom

Zoom

Please make sure that you sign in with your proper first and last name.
Bitte stellen Sie sicher, dass Sie sich mit Ihrem korrekten Vor- und Nachnamen anmelden.



Mikrophone muted

Please have all microphones muted unless you want to contribute verbally
Bitte schalten Sie alle Mikrofone stumm, es sei denn, Sie möchten sich verbal beteiligen



Communicate actively

You can use the chat function for mutual communication.
Speak out freely via microphone if you have questions or comments.
Sie können die Chat-Funktion zur gegenseitigen Kommunikation nutzen.
Äußern Sie sich frei über das Mikrofon, wenn Sie Fragen oder Kommentare haben.



Breaks

Lecturers announce breaks (about every hour) and their duration
Dozierende geben Pausen (ca. stündlich) und deren Dauer bekannt



No video and sound recordings

Lectures may not be recorded without the prior consent of each and every participant!
Vorlesungen dürfen ohne vorherige Zustimmung jedes einzelnen Teilnehmers nicht aufgezeichnet werden!

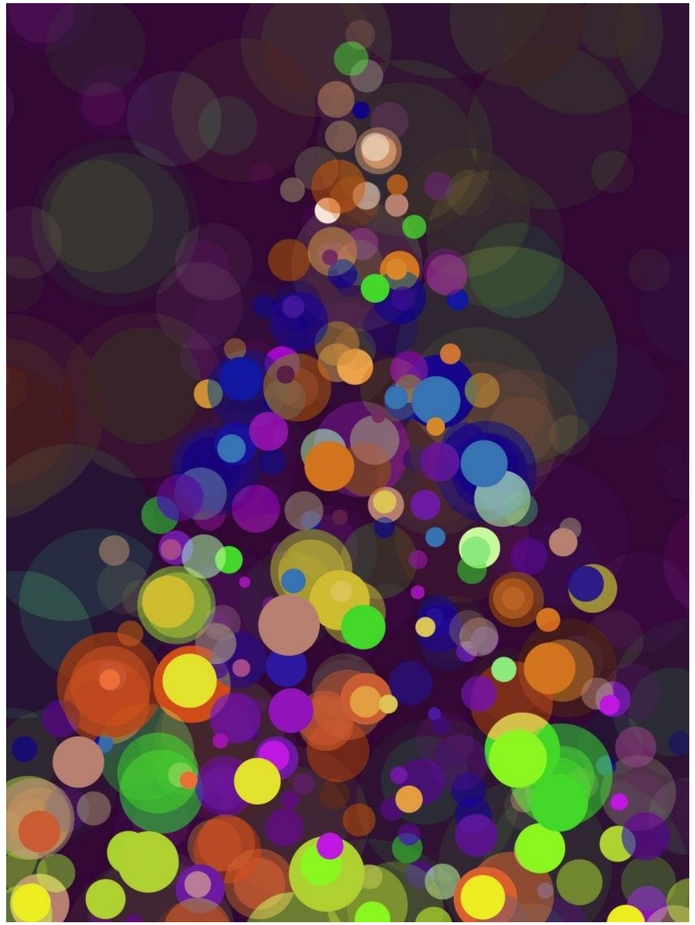
Lernziele SPREN

- Eure Fähigkeiten:
  - Denken wie ein Angreifer, um Sicherheitsrisiken vorauszusehen
  - Schnelle und präzises Beantwortung von Sicherheitsfragen
  - Anwendung eines Frameworks zur Einordnung neuer technischer Erkenntnisse
  - Umgang mit Unklarheiten und Entwicklung von Strategien zu deren Klärung
  - Treffen von risikobasierten Entscheidungen, auch bei unvollständigen Informationen
  - Abgabe fundierter Handlungsempfehlungen
  - Förderung effektiver Zusammenarbeit, auch mit herausfordernden Projektpartnern

Wie?

- Durch konkretes abarbeiten am Beispiel:
  - SPREN1: Ihr übernehmt die Rolle des ICS Berater im Entwicklungsprojekt (Fallstudie)
  - SPREN2: Konkrete Projekte, die ihr als ICS Studierende als Security Berater betreut

Von Berufssituationen zu kompetenzorientierten Lernzielen (SPREN)



- **Beschreibung einer typischen Situation aus dem zukünftigen Berufsfeld, welche die Student:innen nach der Lehrveranstaltung bewältigen können:**
  - In einer Rolle als Information Security Officer ein Produkt- oder IT Entwicklungsprojekt fachlich begleiten und basierend auf Geschäftsrisiken dem Projekt zu helfen angemessene Sicherheitsmassnahmen zu identifizieren und die Bereitstellung der notwendigen Ressourcen sicherzustellen.

Zentrale Handlungskompetenzen für die Bewältigung der Berufssituation:

- Beschaffung von Informationen zu dem zu betreuenden Projekt.
- Realisieren, dass die perfekte Situation nicht existiert. Die Projektzusammenarbeit ist entweder zu früh oder zu spät, die Projektziele oft nicht klar.
- Identifizieren von Chancen für die Zusammenarbeit aus der Zusammenarbeit.
- Qualifizierte Annahmen treffen, um Informationslücken zu überwinden und Cybersecurity bezogene Entscheidungen zu treffen.
- In der Lage sein gegenüber Entscheidern technische Sicherheitsschwachstellen als Risiken für den Geschäftsbetrieb zu formulieren. Dies mit dem Ziel Massnahmen zur Verbesserung der Sicherheit zu «verkaufen».

Kompetenzdimensionen und Kompetenzbereiche

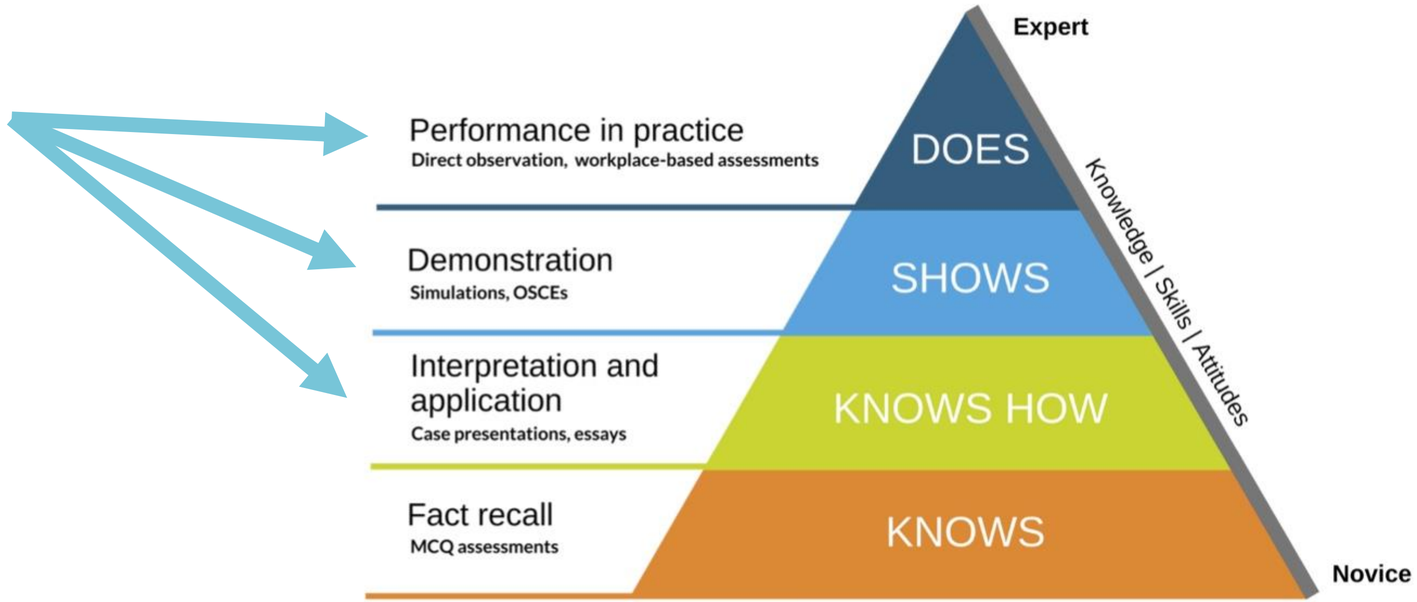
	Wissen	Einstellungen	Fertigkeiten
Fachkompetenzen	Risikomanagement Methoden Bedrohungsanalyse		Erstellen von Risikopräsentationen. Technische Risiken in Geschäftsrisiken umformulieren.
Sozialkompetenzen		Diplomatisch nachhaken. Beschaffung von Informationen	Zielgruppenorientiert Argumente formulieren und vortragen. Erstellen von Zielgruppenorientierten Präsentationen. «Verkaufen» von nichtfunktionalen Massnahmen.
Selbstkompetenzen		Umgang mit Unklarheiten. Vakuum ertragen. Nicht entmutigen lassen.	

(vgl. Walzik 2012)

Warum lernen wir in dieser Form?

Miller’s Pyramid

Wir bewegen uns in diesen drei Stufen



https://openpress.usask.ca/ideabook/chapter/millers-pyramid-of-clinical-competence/

Gesamtkonzept SPREN

SPREN1

- Theorie
- Fallstudie fiktives Produkt

- MEP
  - 1 MC Test Campus
  - 1 Bewertung Lieferobjekte Fallstudie

SPREN2

- Security Beratung für Projekte
- Projektarbeit

- MEP
  - Regelmässig aktualisierte Projektdoku
  - MC Test Campus
  - Abschlusspräsentation Projektarbeit

Kurs Ablaufplan

Semesterwoche	Datum	Durchführung	Kurs	Thema	Dozent	Art
SW01	18.09.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Begrüssung und Gruppeneinteilung	Alex, Chris, Lothar	Unterricht
SW02	25.09.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Product Security Lifecycle - Pre-Launch (I)	Alexander Diekmann	Unterricht
SW03	02.10.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Product Security Lifecycle - Pre-Launch (II)	Alexander Diekmann	Unterricht
SW04	09.10.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Product Security Lifecylce - Pre-Launch (III)	Alexander Diekmann	Unterricht
SW05	16.10.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Security Architecture & Design (I)	Chris Ditze-Stephan	Unterricht
SW06	23.10.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Coaching Projektfallstudie	Lothar Gramelspacher	Coaching
SW07	30.10.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Product Security Risk Management (I)	Alexander Diekmann	Unterricht
SW08	06.11.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Product Security Risk Management (II)	Alexander Diekmann	Unterricht
SW09	13.11.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Coaching Projektfallstudie	Alexander Diekmann	Unterricht & Gruppenarbeit
SW10	20.11.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Security Architecture & Design (II)	Chris Ditze-Stephan	Unterricht & Gruppenarbeit
SW11	27.11.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Coaching Projektfallstudie	Chris Ditze-Stephan	Unterricht
SW12	04.12.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Security Testing in Product Development	Chris Ditze-Stephan	
SW13	11.12.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Security Testing in Product Dev. Uebung	Chris Ditze-Stephan	Unterricht
SW14	18.12.2026	Freitag, Block 2 (12:50-15:10)	SPREN1	SPREN1 Supply Chain Security	Alexander Diekmann	

Termpaper – LLM (Large Language Model, zB ChatGPT) Verwendung

- Kann als Quelle für Stand der Technik etc. verwendet werden

Voraussetzungen:

- LLM muss korrekt als Quelle angegeben und zitiert werden
- Aussagen von LLM müssen auf ihre Korrektheit überprüft werden
- Es muss eine kritische Reflexion über die Verwendung von Tools wie LLM vorhanden sein



Beispiel, wie ChatGPT verwenden?

IT vs OT

please provide in a table the difference between IT and OT Cybersecurity

ChatGPT:

Certainly! Information Technology (IT) and Operational Technology (OT) are two distinct domains in the field of cybersecurity, each with its own set of challenges and requirements. Here's a table outlining the key differences between IT and OT cybersecurity:

It's important to note that with the increasing convergence of IT and OT systems in modern industrial environments (commonly referred to as Industrial IoT or Industry 4.0), the lines between IT and OT cybersecurity are becoming more blurred, and a holistic approach is often necessary.

Aspect	IT Cybersecurity	OT Cybersecurity
Focus	Primarily focused on data, information, and systems	Primarily focused on industrial control systems (ICS), automation, and processes
Purpose	Protects confidentiality, integrity, and availability of information	Ensures the safety, reliability, and availability of operational processes and equipment
Network Architecture	Uses standard networking protocols and technologies	Utilizes specialized industrial protocols and proprietary systems
Endpoints	Includes traditional IT devices (servers, computers, laptops)	Involves specialized OT devices such as PLCs (Programmable Logic Controllers), SCADA systems, sensors
Updates and Downtime	Regular software updates and patches are common	Limited downtime is critical; updates often require careful planning to avoid disruption
Risk Tolerance	Tends to have higher risk tolerance for brief downtime	Very low tolerance for downtime due to potential safety and operational risks
Security Controls	Emphasizes confidentiality and data protection	Prioritizes safety, reliability, and process integrity; often involves physical security
Regulatory Compliance	Compliance with data protection and privacy regulations	Compliance with industry-specific regulations (e.g., NIST, IEC 62443)
Threat Landscape	Faces a wide range of cyber threats, including data breaches and ransomware	Primarily concerned with threats that can impact physical processes, such as equipment failure or process manipulation
Incident Response	Focuses on restoring data and system functionality	Requires a combination of IT and engineering expertise to address both digital and physical consequences
Personnel Skills	Typically involves IT security professionals	Requires a mix of IT and engineering skills; understanding of industrial processes is crucial
Vendor Diversity	Wide range of vendors and products available	Often relies on specialized vendors with expertise in industrial control systems

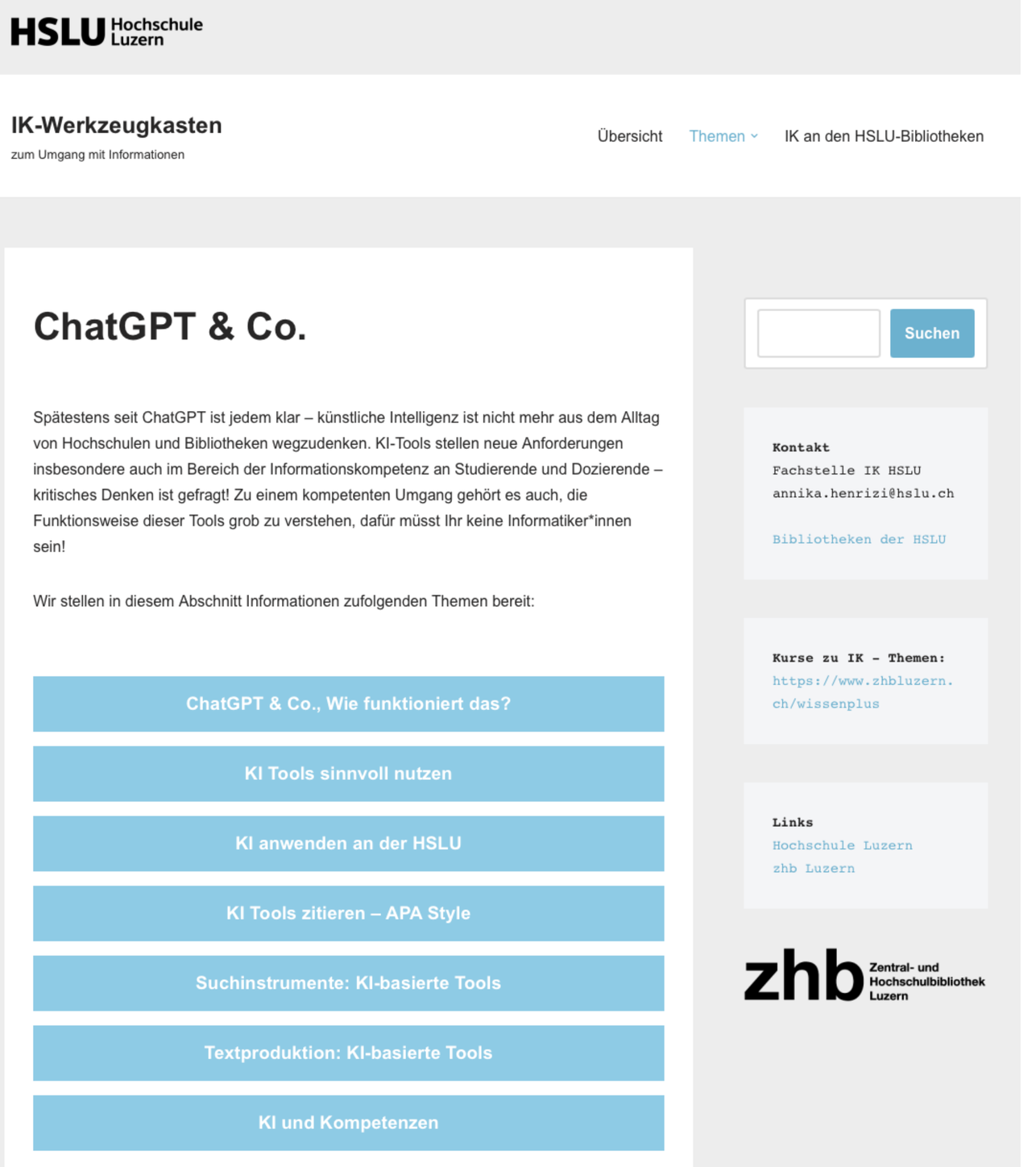
Beispiel, wie ChatGPT verwenden?

what is the lifespan of an IT system vs an OT system?

ChatGPT
The lifespan of IT (Information Technology) and OT (Operational Technology) systems can vary significantly based on factors such as technology advancements, industry requirements, and organizational needs. Here's a general comparison:

System Type	Typical Hardware Lifespan	Typical Software Lifespan	Key Factors Influencing Lifespan
IT System	3 to 5 years	Variable, influenced by evolving business needs, support, and security considerations.	Hardware: Typically 3 to 5 years, influenced by rapid technological changes. Software: Variable, influenced by evolving business needs, support, and security considerations.
OT System	10 to 20 years	Variable, influenced by the need for stability, safety, and the high cost and complexity of upgrades.	Hardware: Typically 10 to 20 years, influenced by the stability and safety prioritized in operational environments. Software: Variable, influenced by the need for stability, safety, and the high cost and complexity of upgrades.

https://blog.hslu.ch/ikwerkzeugkasten/chatgpt-co/



Vorbereitung Vorstellungsrunde

Bitte jeder für sich selbst vorbereiten

- Warum Security Studium?
- Was war das prägende Erlebnis/ Auslöser, dass euch zu dieser Entscheidung bewegt hat?
- Wie schätzt Ihr eure Cyber Security Erfahrung selber ein
  (wenig 1 – viel 6) und wieso?

- Was erwartet ihr von diesem Modul?

Präsentation jeder einzeln (60 Sec) mit Kamera

Fallstudie SPREN1

Sie sind der CISO eines Unternehmens, das automatisierte Produkte (Industrial OT) herstellt. Bis anhin war Ihre Aufgabe auf die interne Informatik beschränkt.

Durch die sich ändernden regulatorischen Anforderungen und Vernetzung rücken nun auch Cyber Security Risiken aus dem Bereich der Produkte in Ihren Fokus.

Die Unternehmensleitung hat Sie aufgefordert zu einem der führenden Produkte des Unternehmen eine Cybersicherheits Analyse zu erstellen und Sicherheitsmassnahmen vorzuschlagen. Regulatorische Anforderungen der Zielmärkte um eine Marktzulassung zu erreichen sind auch zu erfüllen.

Das Entwicklungsprojekt ist bereits am Laufen.

Das Produkt ist im Anhang beschrieben.

Die Produktbeschreibung hat das Produktmanagement mit KI generiert. Somit kann es Unklarheiten und Widersprüche enthalten. Deswegen diese gründlich verifizieren und mit dem Produktmanagement (SPREN1 Coach) abklären.

Folgende Aspekte des Projektes sind durch die Studierenden zu definieren:

Deadlines (Projekt läuft schon, Abschluss gegen Ende Semester)

Zielmärkte (Regionen / Länder)
- Europa und/ oder USA und/ oder China

Laws & Regulations

Lieferobjekte – Bewertungskriterien

Zu finden im ILIAS: Informationen zum Modul > Bewertungsraster_WIPRO_BAA.xlsx

- Wir bewerten nach dem offiziellen Bewertungsraster der HSLU für BAA und WIPRO. Es wird die BAA Gewichtung verwendet.
- Punkt 1 ”Auftragsklärung und Zwischenpräsentation” wird nicht bewertet
- Punkt 5 ”Auftragsklärung und Zwischenpräsentation” wird nicht bewertet

	WIPRO	BAA
1. Auftragsklärung und Zwischenpräsentation	15 %	20%
1.1. Projektmanagement		
1.2. Selbständigkeit		
1.3. Formelle Beurteilung der Zwischenpräsentation		
1.4. Inhaltliche Beurteilung der Zwischenpräsentation		
1.5. Auswahl der Technik(en)/ Methode(n) in Bezug auf den Kontext des Auftrages		
2. Engineering und Methodik	15%	20%
2.1. Anwendung der gewählten Technik(en)/ Methode(n)		
2.2. Aufbau und Nachvollziehbarkeit der Arbeit		
2.3. Umgang mit Daten, Informationen und deren Referenzierung		
3. Ergebnisse	35%	25%
3.1. Erreichung der festgelegten Ziele und Validierung		
3.2. Inhaltliche Aufarbeitung des Forschungsstands/ dem Stand der Technik(en)		
3.3. Qualität der erstellten Artefakte		
3.4. Praktischer Nutzen der Ergebnisse für den Auftraggebenden		
3.5. Kritische Reflexion des Prozesses zur Lösungsfindung		
4. Sprache und Form	5%	5%
4.1. Formale und grafische Qualität		
4.2. Sprachliche Qualität		
5. Gesamtprojekt und Verteidigung	30%	30%
5.1. Formelle Beurteilung der Abschlusspräsentation		
5.2. Inhaltliche Beurteilung der Abschlusspräsentation		
5.3. Kompetenz bei abschliessender Befragung		
5.4. Kreativität und Innovation des Gesamtprojektes		
Total Gewichtung	**100%**	**100%**

Gruppeneinteilung

Modulendprüfung SPREN1

Schriftliche Abgaben als Gruppenaufgabe (bewertet)

Ein Multiple Choice Test (über 3 Thementeile)

Verteilung

– Lieferobjekte Fallstudie	Gruppe	Paper	51%
– Security & Architecture & Testing	Einzeln	MultipleChoice	49%

  – MCT vor Ort mit Aufsicht closed Book (Pen & Paper)

Zeitaufwand pro Semester

90h für das ganze Modul für einen durchschnittlichen Stud.

- 3 ECTS Punkte

- 35h (42 Lektionen Unterricht)
- 40h arbeiten (inkl. Lesen, Übungen und Berichte)
- 15h Lernen/ Vorbereiten für die Prüfung

Die Fallstudie löst ihr zu zusammen

- nutzt die Gruppe

HSLU Lucerne University of Applied Sciences and Arts

the End (for today)

School of Computer Science and Information Technology
Degree Programs
Lothar Gramelspacher
Lecturer

Phone direct +41 41 349 31 16
lothar.gramelspacher@hslu.ch

SPREN1 In a Nutshell

- MEP = 51% Benotung SAFe (Gruppe) + 49% MCT (einzeln)
- Multiple Choice Test (MCT) findet vor Ort in Rotkreuz statt -> Prüfungsphase!
- Veranstaltungen sind Remote. Manchmal auch mit einem Dozenten vor Ort. Dann in hybrider Durchführung.
- Sämtliche Kommunikation findet über das ILIAS Forum statt.
- Abgabetermin und Abgabe in ILIAS.
- Ein Termpaper wird in der Gruppe geschrieben.
- Coaching Sessions!
  - Nutzt die Coaching Sessions.
  - Bucht gruppenindividuelle Termine
    - in den Modulzeiten
    - andere Zeiten
    - auf Anfrage

Fragen?

Gibt es Überlappungen zu anderen Kursen?

- Ja, sicheres Programmieren. Aber mit einem anderen Focus.